

INFORME TÉCNICO DE AUDITORÍA DE SEGURIDAD

Hallazgos Críticos en el Portal Administrativo Interno

Control de versiones

Versión

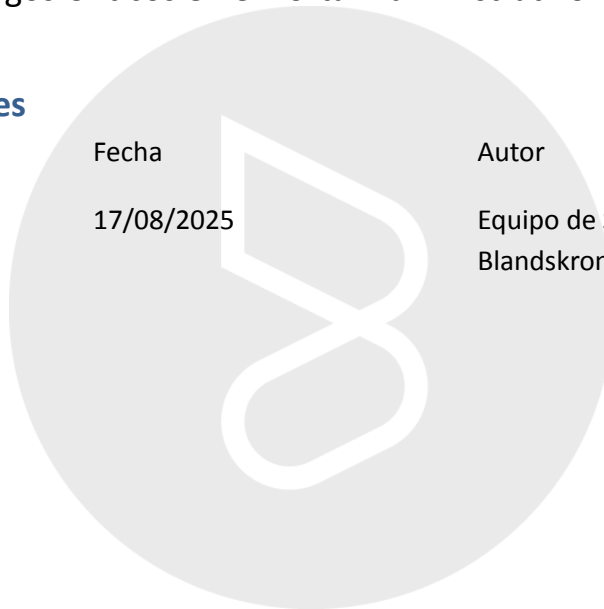
1.0

Fecha

17/08/2025

Autor

Equipo de Seguridad -
Blandskron SpA



Resumen Ejecutivo

Durante la revisión de seguridad del portal administrativo interno se detectaron múltiples hallazgos críticos relacionados con la gestión de autenticación y almacenamiento de credenciales. Las deficiencias observadas exponen el entorno a ataques de fuerza bruta, accesos no autorizados y compromiso total de la información sensible. Este informe presenta los hallazgos identificados, su impacto y las recomendaciones técnicas para mitigar los riesgos.

Título del Informe

Deficiencias Críticas en la Gestión de Autenticación y Credenciales en el Portal Administrativo Interno

Tabla de Hallazgos y Recomendaciones

Hallazgo	Impacto	Recomendación técnica
Sin límite de intentos en login	Expone el sistema a ataques de fuerza bruta que permiten adivinar credenciales.	Implementar bloqueo progresivo por IP y retardo incremental tras múltiples intentos fallidos.
Sin autenticación multifactor (MFA)	El compromiso de credenciales expone a accesos no autorizados sin barreras adicionales.	Habilitar MFA obligatorio para cuentas administrativas y sensibles.
Contraseñas en texto plano	Compromiso total de cuentas si la base de datos es accedida por un atacante.	Implementar almacenamiento seguro de contraseñas con hash fuerte (bcrypt, Argon2).
Sin política de contraseñas seguras	Usuarios pueden emplear contraseñas débiles que aumentan la probabilidad de ataques exitosos.	Aplicar políticas de complejidad, longitud mínima y caducidad periódica.

Desarrollo Detallado del Hallazgo: Contraseñas en Texto Plano

Evidencia Técnica

Durante la revisión de la base de datos del portal administrativo se verificó que las credenciales de usuario se almacenan en texto plano sin ningún mecanismo de cifrado o hash. Esta práctica fue confirmada mediante consultas SQL directas que mostraron las contraseñas legibles de múltiples cuentas.

Impacto Potencial

El almacenamiento de contraseñas en texto plano representa una vulnerabilidad crítica. En caso de que un atacante obtenga acceso a la base de datos, todas las cuentas del sistema quedarían comprometidas de inmediato, permitiendo accesos no autorizados, robo de información sensible y escalamiento de privilegios.

Recomendación Técnica

Se recomienda implementar el almacenamiento seguro de contraseñas utilizando algoritmos de hash robustos como bcrypt o Argon2, con la adición de sal aleatoria única por cada contraseña. Además, se deben establecer controles periódicos para verificar que ninguna credencial se encuentre en formato no cifrado.